Theoretical Knowledge: Threat Intelligence Integration

1. Core Concepts

1.1 Threat Intelligence Types

Threat intelligence is evidence-based knowledge about existing or emerging threats that enables informed security decisions. It is categorized into multiple layers:

A. Indicators of Compromise (IOCs)

IOCs are forensic artifacts that indicate a system has been compromised. They are the most tactical and actionable form of threat intelligence.

IOC Type	Description	Example
IP Addresses	Known malicious IPs (C2 servers, scanners)	`185.220.101.45` — Tor Exit Node used by APT29
Domain Names	Malicious or phishing domains	`login-microsfot[.]com` — Credential harvesting
File Hashes	MD5/SHA256 of malware samples	`d41d8cd98f00b204e9800998ecf8427e`
URLs	Specific malicious URLs hosting payloads	`hxxp://evil[.]com/payload.exe`
Email Addresses	Addresses used in phishing campaigns	`admin@secure-update[.]net`
Registry Keys	Windows registry modifications by malware	`HKLM\Software\Microsoft\Windows\CurrentVersion\Run\malware`

Mutex Names	Unique mutex created by malware families	`Global\MalwareMutex_XYZ`

B. Tactics, Techniques, and Procedures (TTPs)

TTPs describe **how** adversaries operate, mapped to the MITRE ATT&CK framework. Unlike IOCs (which change frequently), TTPs are more persistent and harder for adversaries to modify.

Layer	Description	Example
Tactics	The adversary's goal (the "why")	Initial Access, Lateral Movement, Exfiltration
Techniques	How the tactic is achieved (the "how")	T1566 — Phishing, T1078 — Valid Accounts
Sub-Techniques	Specific variation of a technique	T1566.001 — Spearphishing Attachment
Procedures	Exact implementation by a specific group	APT28 uses macro-enabled Word documents for T1566.001

MITRE ATT&CK Matrix (Key Tactics):

```
┌──────────────────┬──────────────────┬──────────────────┬──────────────────┐
│ Initial Access   │ Execution        │ Persistence      │ Privilege Escal. │
│ T1566 Phishing   │ T1059 Command    │ T1053 Scheduled  │ T1548 Abuse      │
│ T1078 Valid Accts │   Line Interface │   Task/Job       │   Elevation Ctrl │
├──────────────────┼──────────────────┼──────────────────┼──────────────────┤
│ Defense Evasion  │ Credential Access│ Discovery        │ Lateral Movement │
│ T1070 Indicator  │ T1003 OS Cred.   │ T1087 Account    │ T1021 Remote     │
│   Removal        │   Dumping        │   Discovery      │   Services       │
```

```
├──────────────────┼──────────────────┼────────────────────┼──────────────────
┤ │ Collection       │ C2               │ Exfiltration       │ Impact           │
│ T1005 Data from  │ T1071 Application│ T1041 Exfil Over   │ T1486 Data       │
│   Local System   │   Layer Protocol │   C2 Channel       │   Encrypted      │
└──────────────────┴──────────────────┴────────────────────┴──────────────────┘
```

C. Threat Feeds (STIX/TAXII)

Standard	Purpose	Description
STIX (Structured Threat Information eXpression)	Data Format	JSON-based language for describing threat intelligence (IOCs, TTPs, threat actors, campaigns)
TAXII (Trusted Automated eXchange of Intelligence Information)	Transport Protocol	Defines how STIX data is shared between systems (via collections and channels)

STIX Object Example (Malicious IP Indicator):

```
{
  "type": "indicator",
  "id": "indicator--8e2e2d2b-17d4-4cbf-938f-98ee46b3cd3f",
  "created": "2025-08-18T00:00:00.000Z",
  "name": "Malicious IP - C2 Server",
  "pattern": "[ipv4-addr:value = '185.220.101.45']",
  "pattern_type": "stix",
  "valid_from": "2025-08-18T00:00:00Z",
  "labels": ["malicious-activity"],
  "description": "Known C2 server associated with APT29 operations"
}
```

1.2 Integration in SOC — SIEM Enrichment

Threat intelligence becomes actionable when integrated into SIEM platforms for **automated alert enrichment**.

Integration Workflow:

```
┌──────────────────┐      ┌────────────────────┐      ┌──────────────────┐
│  Threat Feeds    │──────▶│   SIEM Platform    │──────▶│  Enriched Alert  │
│  (OTX, MISP,     │      │  (Wazuh, Elastic,  │      │  with IOC match, │
│   VirusTotal)    │      │   Splunk, QRadar)  │      │  reputation,     │
└──────────────────┘      └────────────────────┘      │  TTP mapping     │
                                                       └──────────────────┘
```

Example Scenario: Matching a Suspicious IP to a Known C2 Server

1. Wazuh ingests a firewall log showing connection from internal host `192.168.1.100` to external IP `185.220.101.45` .
2. Wazuh's CDB (Constant Database) list is loaded with IOCs from AlienVault OTX.
3. The IP `185.220.101.45` matches the C2 feed → Wazuh automatically enriches the alert.
4. The enriched alert now shows: **"Connection to known C2 server (APT29, Confidence: High)"**.
5. Alert is auto-escalated to **High priority** and assigned to Tier 2.

Wazuh CDB List Configuration (`/var/ossec/etc/lists/threat-intel`):

```
185.220.101.45:C2 Server - APT29
91.219.236.222:Botnet Controller - Emotet
203.0.113.50:Phishing Infrastructure
```

Wazuh Rule for IOC Matching:

```
<rule id="100200" level="12">
  <if_sid>5710</if_sid>
  <list field="srcip" lookup="address_match_key">etc/lists/threat-intel</list>
  <description>Connection to known malicious IP: $(srcip)</description>
  <mitre>
    <id>T1071</id>
  </mitre>
</rule>
```

1.3 Threat Hunting with Intelligence

Threat hunting is the **proactive** search for threats that evade automated detection. Unlike reactive alerting, hunting uses hypothesis-driven investigation to find adversaries that are already inside the network.

Threat Hunting Cycle:

```
┌──────────────┐
│ 1. Hypothesis │◀── Threat Intelligence (TTPs, IOCs)
└──────┬───────┘
       ▼
┌──────────────┐
│ 2. Investigate │◀── SIEM Queries, EDR Telemetry
└──────┬───────┘
       ▼
┌──────────────┐
│ 3. Discover   │──▶ True Positive → Incident Response
└──────┬───────┘      False Positive → Refine Detection
       ▼
┌──────────────┐
│ 4. Automate   │──▶ Create new detection rule
└──────────────┘
```

Example: Hunting for T1078 — Valid Accounts Misuse

Hypothesis: An attacker may have obtained valid credentials and is using a legitimate user account to move laterally.

Hunt Queries (Wazuh/Elastic):

```
# Find logins from service accounts that shouldn't be interactive user.name:("svc_*"
OR "service_*") AND event.action:"logon" AND logon.type:"Interactive

# Find accounts logging in outside business hours event.id:4624 AND @timestamp:[now-
1d/d TO now] AND hour_of_day:(0 OR 1 OR 2 OR 3 OR 4 O

# Find accounts authenticating to multiple hosts rapidly event.id:4624 | stats
dc(host.name) as unique_hosts by user.name | where unique_hosts >

# Find impossible travel — same account from different geolocations
user.name:"jsmith" AND event.id:4624 | stats values(source.geo.country_name) as countri
```

Indicators of T1078 Misuse:

- Service account used interactively
- Login from unusual geolocation
- Same account on 10+ hosts in 30 minutes
- Login immediately after password reset from unknown device
- Account activity outside user's normal working hours

2. Key Objectives

- Build proficiency in leveraging threat intelligence to enhance detection and response capabilities.
- Understand how to ingest, normalize, and operationalize IOCs within SIEM platforms.
- Develop hypothesis-driven threat hunting skills using MITRE ATT&CK TTPs.
- Master STIX/TAXII standards for consuming and sharing threat intelligence.

3. Study Resources

Resource	Focus Area	Link
MITRE ATT&CK Framework	TTPs, adversary behavior modeling	https://attack.mitre.org/
OASIS STIX/TAXII Documentation	Threat intelligence sharing standards	https://oasis-open.github.io/ctidocumentation/
AlienVault OTX	Open threat exchange, IOC feeds	https://otx.alienvault.com/
Wazuh Threat Intelligence Docs	SIEM integration with threat feeds	https://documentation.wazuh.com/
SANS — Threat Hunting with ATT&CK	Practical threat hunting techniques	https://www.sans.org/white-papers/
VirusTotal API Documentation	IOC validation and enrichment	https://developers.virustotal.com/

4. Real-World Application: SolarWinds Supply Chain Attack (2020)

The SolarWinds attack (SUNBURST) demonstrated the critical importance of threat intelligence integration:

- **IOCs** (specific DLLs with known hashes, C2 domains like `avsvmcloud[.]com`) were published by FireEye and rapidly shared via STIX/TAXII feeds.
- Organizations that had **automated threat feed ingestion** could immediately scan their environments for the compromised DLL (`SolarWinds.Orion.Core.BusinessLayer.dll` , SHA256: `ce77d116a074dab7a22a0fd4f2c1ab475f16eec42e1ded3c0b0aa8211fe858d6`).
- Those without threat intelligence integration took **weeks** to determine if they were affected.
-

Lesson: Automated threat intelligence integration is not a luxury — it is essential for rapid detection and response.

Document prepared as part of SOC Analyst Training — Theoretical Knowledge Module